

Chapter 16

Incident Response

Preparation and Detection

Preparation happens before an incident strikes.

- Firewalls, patching, training, and certs build readiness
- Detection means continuous monitoring for suspicious activity
- Spot something unusual? Escalate to analysis

Analysis and Triage

Determine whether a detection is truly malicious.

- Cross-check findings against threat intelligence
- Triage: is this nothing, or something requiring action?
- Confirmed? Escalate. Not confirmed? Document and monitor

Containment and Eradication

Stop the spread, then remove every trace.

- Isolate systems — take them offline or cut network access
- Assess scope, timeline, and financial impact
- Wipe and reimage — one missed backdoor undoes everything

Recovery and Lessons Learned

Restore operations, then document what happened.

- Restore OS, recover data, return systems to normal
- Lessons learned: facts only, no blame, log hours not dollars
- Write for your future self — what worked and why

Chapter 16

Incident Response Management

The Weight of the Word “Incident”

Declaring an “incident” triggers mandatory reporting

Teams use softer terms until a senior leader makes the formal call

Activating the Communications Plan

Pre-built comms plan activates immediately on declaration

Legal, PR, regulators, and law enforcement briefed on need-to-know basis

What Stakeholders Want to Know

Legal: accountability

PR: damage control
and messaging

Regulators: root cause

Customers: data safety assurance

Securing Communication Channels

Attackers may monitor corporate channels — use out-of-band alternatives

Control terminology and limit information access

Shift Handoffs and Continuity

Formal handoffs with documented findings at every shift change

Ensures consistent response around the clock

Chapter 16

Incident Reporting

Incident Reporting Basics

Notify based on legal and need-to-know criteria

Tailor detail level to audience type

Tailoring Reports by Audience

Technical: CVEs, IOCs, and threat intelligence

Executives: Business impact and remediation

Regulators: Control gaps and compliance

Risk Scorecards and POA&M

Scorecards map risks to KPIs and reveal security gaps

POA&M drives remediation;
required for federal networks

Escalation Procedures

Some incidents exceed technician authority

Escalate internally to senior staff or externally to consultants

Executive Summaries and Regulatory Reports

Executive summaries: non-technical, focused on impact and remediation

Regulatory reports: controls and audit evidence, varies by industry